

Des agents IA pour analyser les risques

Sujet de projet autonome : toutes les notions nécessaires sont expliquées dans ce document

Yulliwas AMEUR

Sup de Vinci Rennes · Projet de groupe

Ce que vous allez faire

Objectif

Le quoi

Concevoir un **système de plusieurs agents IA** qui aide un analyste à réaliser l'**analyse de risques** d'un système informatique.

Enjeu

Le pourquoi

Une analyse de risques est longue et répétitive. L'IA peut accélérer le travail, à condition d'être **encadrée et vérifiée**.

Livrable

Le résultat

Un **registre des risques** argumenté, produit par vos agents puis validé par un humain, et une présentation de votre architecture.

À RETENIR Le but n'est pas de remplacer l'analyste de sécurité, mais de l'**assister**. L'humain reste responsable de la décision finale.

Organisation pratique

Élément	Modalité
Travail	En groupe de 4 étudiants
Durée	1h (45 min de soutenance + 20 min de questions)
Outils autorisés	Tout outil d'IA ou de programmation, à condition de le citer (LLM, framework d'agents, no-code)
Système à analyser	Un des cas d'étude proposés, ou un cas de votre choix validé par l'enseignant
Rendu	Un dossier écrit, un prototype ou une maquette, et une soutenance de 45 minutes

NOTE Les éléments entre crochets sont fixés par l'enseignant au lancement du projet.

Pourquoi utiliser l'IA pour analyser les risques ?

Le problème

- Une analyse de risques prend des jours
- Elle demande des experts rares
- Elle doit être refaite à chaque changement
- Beaucoup d'étapes sont répétitives

Ce que l'IA sait faire

- Lire et résumer une documentation
- Appliquer une grille de questions
- Rechercher des vulnérabilités connues
- Rédiger un premier jet structuré

Ce que l'IA fait mal

- Elle peut inventer des faits
- Elle ne connaît pas le contexte métier
- Elle peut être manipulée
- Elle n'est pas responsable

À RETENIR Votre travail consiste à tirer parti des forces de l'IA tout en maîtrisant ses faiblesses.

01

CHAPITRE 01

Les notions indispensables

Le minimum à connaître en gestion des risques pour réussir le projet.

- Le vocabulaire du risque
- La démarche d'analyse en six étapes
- Évaluer et traiter un risque
- Modéliser les menaces avec STRIDE
- Le registre des risques

Six mots pour parler de risque

Terme	Définition simple	Exemple
Actif	Tout ce qui a de la valeur pour l'organisation	La base de données clients
Menace	Ce qui peut causer un dommage	Un rançongiciel
Vulnérabilité	Une faiblesse qu'une menace peut exploiter	Un serveur non mis à jour
Risque	La possibilité qu'une menace exploite une vulnérabilité, avec un impact	Clients privés de service pendant 3 jours
Contre-mesure	Une mesure qui réduit le risque	Sauvegardes hors ligne, correctifs
Risque résiduel	Le risque qui reste après les contre-mesures	Risque « moyen », accepté par la direction

À RETENIR $\text{Risque} = \text{Menace} \times \text{Vulnérabilité} \times \text{Impact}$. Sans vulnérabilité, la menace ne peut rien ; sans menace, la faiblesse ne coûte rien.

L'analyse de risques en six étapes

1 Identifier les actifs
Lister ce qui a de la valeur et estimer cette valeur.

2 Choisir une méthode
Décider quelle grille de menaces utiliser.

3 Identifier les menaces
Chercher ce qui peut mal tourner pour chaque actif.

4 Évaluer les risques
Noter la probabilité et l'impact de chaque menace.

5 Traiter les risques
Choisir une réponse et des contre-mesures.

6 Valider et suivre
Faire relire, décider, puis revoir régulièrement.

À RETENIR Chaque étape de cette démarche deviendra un agent de votre système.

ÉVALUER UN RISQUE

La matrice probabilité × impact

On donne à chaque menace une **probabilité** (va-t-elle se produire ?) et un **impact** (quelle gravité si elle se produit ?). La case obtenue donne le niveau de risque.

Probabilité ↓ · Impact →	Faible	Moyen	Élevé
Élevée	Moyen	Élevé	Critique
Moyenne	Faible	Moyen	Élevé
Faible	Faible	Faible	Moyen

À RETENIR Autres grilles possibles : **DREAD** (5 critères notés de 1 à 10) ou **CVSS** (note de 0 à 10 pour une vulnérabilité connue). Choisissez-en une et justifiez-la.

Quatre réponses possibles

Ex. : MFA, correctifs

Réduire

Mettre en place des contre-mesures pour baisser la probabilité ou l'impact.

Ex. : cyber-assurance

Transférer

Faire porter une partie du risque par un tiers.

Ex. : fermer un service exposé

Éviter

Arrêter l'activité qui crée le risque.

Ex. : risque faible et coûteux à traiter

Accepter

Garder le risque, par une décision écrite de la direction.

À RETENIR Ignorer un risque sans décision n'est jamais une réponse acceptable.

Modéliser les menaces

En anglais : Threat modeling

DÉFINITION

Démarche structurée qui consiste à **décrire un système**, puis à chercher méthodiquement **ce qui peut mal tourner** à chaque endroit, à l'aide d'une grille de questions.

DEUX OUTILS DE DESCRIPTION

- **DFD** (diagramme de flux de données) : schéma des utilisateurs, processus, bases de données et flux
- **Frontière de confiance** : limite où les données changent de zone (ex. Internet → réseau interne)

À RETENIR

Les attaques se produisent surtout au passage des frontières de confiance : c'est là qu'on cherche en priorité.

LA GRILLE PAR DÉFAUT

STRIDE : six questions à poser à chaque élément

Lettre	Menace	Question à poser	Exemple de contre-mesure
S	Usurpation d'identité	Quelqu'un peut-il se faire passer pour un autre ?	Authentification forte (MFA)
T	Falsification	Peut-on modifier les données ?	Signature, contrôle d'intégrité
R	Répudiation	Peut-on nier avoir fait une action ?	Journaux horodatés
I	Divulgation	Des informations peuvent-elles fuiter ?	Chiffrement, contrôle d'accès
D	Déni de service	Peut-on rendre le service indisponible ?	Redondance, limitation de débit
E	Élévation de privilèges	Peut-on obtenir plus de droits ?	Moindre privilège

À RETENIR STRIDE a été créé chez Microsoft. C'est le modèle le plus simple pour commencer : vous pouvez l'utiliser comme grille par défaut.

CHOISIR UN AUTRE MODÈLE

Quel modèle pour quelle question ?

Si votre système...	Modèle possible	En une phrase
traite beaucoup de données personnelles	LINDDUN	Grille de 7 menaces pour la vie privée (liaison, identification...)
doit être relié aux enjeux métier	PASTA	Méthode en 7 étapes, du métier jusqu'à la simulation d'attaques
a un objectif d'attaque précis à détailler	Arbres d'attaque	L'objectif est la racine ; les branches sont les moyens d'y arriver
doit être comparé aux attaques réelles	MITRE ATT&CK	Base publique des techniques utilisées par les vrais attaquants

À RETENIR L'agent « Choix du modèle » devra justifier son choix à partir de ces critères.

Le registre des risques

Registre des risques : tableau qui liste chaque risque, son évaluation, son traitement et son responsable.

Colonne	Exemple de contenu
Identifiant et description	R-07 : vol des identifiants d'un administrateur par hameçonnage
Actif concerné	Console d'administration du site
Catégorie de menace	STRIDE · S (usurpation d'identité)
Probabilité · Impact · Niveau	Moyenne · Élevé · Élevé
Traitement et contre-mesures	Réduire : MFA résistant à l'hameçonnage, sensibilisation
Justification et sources	Règle STRIDE, cas similaires, référence de la mesure
Risque résiduel et validation	Faible · validé par [nom de l'analyste]

02

CHAPITRE 02

Les notions d'IA

Ce qu'est un agent, et pourquoi en utiliser plusieurs.

- LLM, agent, outils, orchestrateur
- Pourquoi un système multi-agents
- Les risques propres à l'IA

Les mots de l'IA utilisés dans le projet

Terme	Définition simple
Grand modèle de langage (LLM)	IA entraînée sur de grandes quantités de texte, capable de comprendre et de produire du texte.
Prompt (consigne)	Instructions écrites données au LLM : son rôle, sa tâche, le format attendu.
Agent IA	Programme qui utilise un LLM pour atteindre un objectif : il planifie, agit par étapes et utilise des outils.
Outil	Fonction que l'agent peut appeler : lire un fichier, interroger une base de vulnérabilités, faire un calcul.
Orchestrateur	Agent « chef d'orchestre » qui distribue le travail et fait circuler les résultats.
RAG	Technique qui fournit au LLM des documents de référence pour qu'il s'appuie sur des sources fiables.
Humain dans la boucle	Une personne valide les résultats importants avant leur utilisation.

Pourquoi plusieurs agents plutôt qu'un seul ?

Spécialisation

Chaque agent a **une seule tâche** et une consigne courte : il se trompe moins qu'un agent qui fait tout.

Contrôle

Chaque résultat intermédiaire est **visible et vérifiable** : on sait quel agent a produit quelle erreur.

Moindre privilège

Chaque agent n'a accès **qu'aux outils** dont il a besoin : un agent compromis fait moins de dégâts.

À RETENIR C'est le même principe que la séparation des tâches dans une organisation : on découpe pour mieux contrôler.

L'IA EST AUSSI UN RISQUE

Les risques propres à votre système d'agents

Risque	Définition	Mesure possible
Hallucination	L'IA invente une information fausse mais crédible	Exiger des sources, validation humaine
Injection de prompt	Un texte piégé dans un document détourne les consignes de l'agent	Filtrer les entrées, séparer consignes et données
Fuite de données	Des données sensibles partent vers un service externe	Anonymiser, utiliser un modèle local
Excès d'autonomie	L'agent agit sur des systèmes réels sans contrôle	Lecture seule, humain dans la boucle
Empoisonnement	La base de connaissances contient de fausses informations	Sources officielles, contrôle des mises à jour
Dépendance	Le service d'IA change, disparaît ou devient payant	Architecture modulaire, modèle remplaçable

À RETENIR Référence : l'OWASP classe l'**injection de prompt** en tête de son Top 10 des risques des applications à base de LLM.

03

CHAPITRE 03

Le système à construire

L'architecture, le rôle de chaque agent et le cas d'étude.

- Entrée, traitement, sortie
- L'architecture globale
- La fiche de chaque agent
- Le format des échanges
- Les cas d'étude

Entrée, traitement et sortie

Ce que l'on fournit

Entrée

- La description du système à analyser
- Son architecture et ses flux de données
- Son contexte métier et ses contraintes (RGPD...)

Ce que font les agents

Traitement

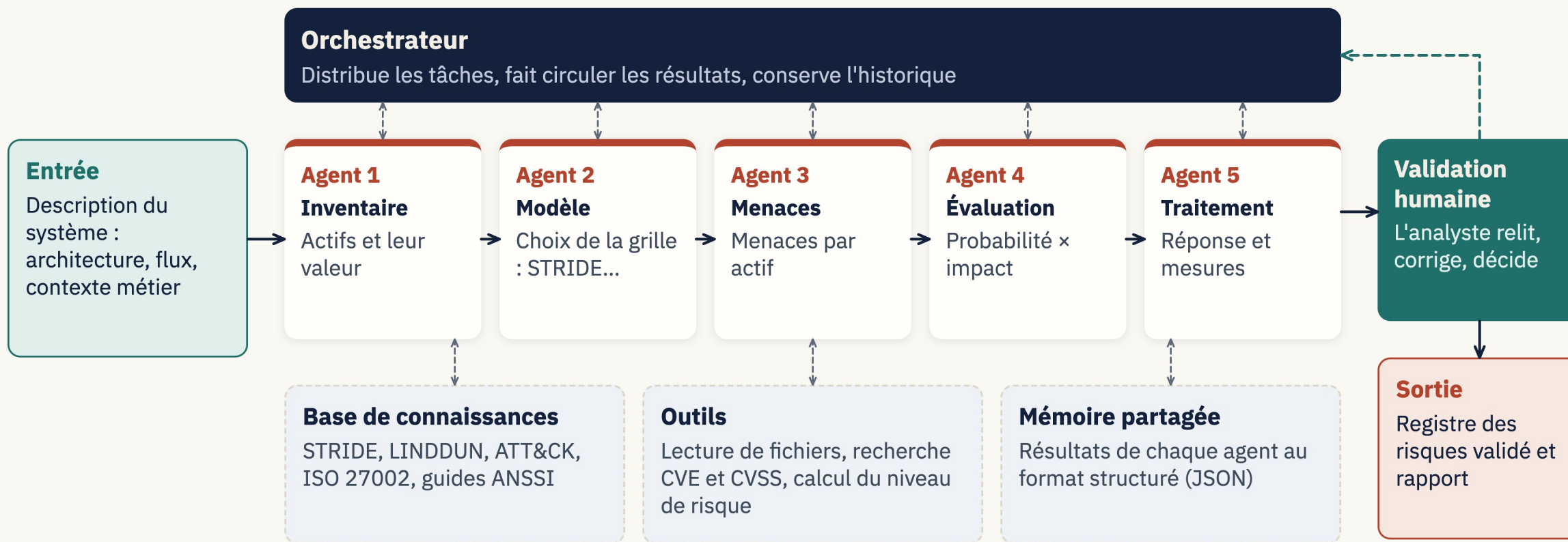
- Une chaîne d'agents spécialisés
- Qui reproduit les six étapes de l'analyse de risques
- Avec des sources de référence

Ce que l'on obtient

Sortie

- Un registre des risques argumenté
- Le modèle de menaces utilisé et sa justification
- Validé par un analyste humain

Le système multi-agents d'analyse de risques



Garde-fous de sécurité, appliqués à tous les agents

Filtrage des entrées (injection de prompt) · Outils en lecture seule · Anonymisation des données · Sources citées pour chaque risque · Journalisation de toutes les actions

LE DÉTAIL

La fiche de chaque agent

Agent	Reçoit	Fait	Produit
1 · Inventaire	La description du système	Repère et classe les actifs, estime leur valeur	Liste des actifs
2 · Modèle	Liste des actifs, contexte	Choisit la grille de menaces et justifie	Modèle retenu + justification
3 · Menaces	Actifs + modèle	Applique la grille à chaque actif et flux	Liste des menaces
4 · Évaluation	Menaces	Note probabilité et impact, calcule le niveau	Menaces notées
5 · Traitement	Menaces notées	Propose une réponse et des contre-mesures	Projet de registre
Orchestrateur	La demande de l'analyste	Lance les agents dans l'ordre, gère les reprises	Historique complet

À RETENIR Chaque agent a sa propre consigne (prompt), écrite par votre groupe : c'est une partie importante du rendu.

Des résultats structurés, faciles à vérifier

```
{
  "id": "R-07",
  "actif": "Console d'administration",
  "menace": "Vol d'identifiants par hameçonnage",
  "categorie": "STRIDE-S",
  "probabilite": "moyenne",
  "impact": "élevé",
  "niveau": "élevé",
  "traitement": "réduire",
  "mesures": ["MFA FIDO2", "sensibilisation"],
  "sources": ["STRIDE", "OWASP ASVS V2"],
  "valide_par": null
}
```

Pourquoi un format structuré ?

Chaque agent lit exactement ce que le précédent a produit. On peut vérifier automatiquement que rien ne manque.

Le champ « sources »

Chaque risque doit citer ses sources : c'est la première parade contre les hallucinations.

Le champ « valide_par »

Il reste vide tant qu'un humain n'a pas validé le risque.

LE CAS D'ÉTUDE

Trois systèmes au choix

Cas	Description	Actifs à ne pas oublier
A · Boutique en ligne	Site marchand d'une PME : site web, paiement par un prestataire, base clients, back-office	Données clients, compte administrateur, disponibilité du site
B · Téléconsultation médicale	Application de rendez-vous et de visio entre patients et médecins	Données de santé, identités, flux vidéo
C · Réseau d'une PME	Postes, messagerie, serveur de fichiers, Wi-Fi, accès à distance des salariés	Comptes, sauvegardes, accès VPN

À RETENIR Pour chaque cas, rédigez d'abord une description d'une page (architecture et flux) : c'est l'entrée de votre système d'agents.

04

CHAPITRE 04

Déroulé et rendu

Les étapes du projet, les livrables et la façon de les préparer.

- Les jalons
- Les livrables
- Les critères d'évaluation
- La liste de contrôle avant le rendu

LES ÉTAPES

Cinq jalons pour mener le projet

1

Cadrer

Choisir le cas, rédiger sa description, lister les actifs attendus.

2

Concevoir

Dessiner l'architecture, écrire la fiche et la consigne de chaque agent.

3

Prototyper

Faire fonctionner la chaîne sur le cas choisi (code ou outil sans code).

4

Tester

Comparer le résultat à votre propre analyse ; tester une injection de prompt.

5

Restituer

Rédiger le dossier et préparer la soutenance.

À RETENIR Commencez par faire l'analyse de risques vous-mêmes, à la main, sur quelques actifs : c'est votre référence pour juger les agents.

Les trois livrables

Dossier écrit

- Description du cas étudié
- Architecture et fiche de chaque agent
- Consignes (prompts) utilisées
- Registre des risques obtenu
- Analyse critique des résultats

Prototype ou maquette

- Code, flux sans code ou maquette détaillée
- Exemple d'exécution sur le cas
- Traces des échanges entre agents

Soutenance

- Présentation de l'architecture
- Démonstration
- Ce qui marche, ce qui ne marche pas
- Les risques de votre propre système

Critères d'évaluation (proposition)

Critère	Ce qui est attendu	Poids
Maîtrise de la démarche de risque	Vocabulaire juste, étapes respectées, registre cohérent	[%]
Qualité de l'architecture	Rôles clairs, échanges structurés, orchestrateur pertinent	[%]
Choix et justification du modèle	Modèle adapté au cas et justifié	[%]
Sécurité du système d'agents	Risques de l'IA identifiés et traités	[%]
Esprit critique	Comparaison avec l'analyse manuelle, limites expliquées	[%]
Restitution	Dossier clair, démonstration, réponses aux questions	[%]

NOTE Les pondérations sont fixées par l'enseignant.

La liste de contrôle

N°	Question
1	Chaque risque du registre cite-t-il un actif, une menace, un niveau et une source ?
2	Le choix du modèle de menaces est-il justifié par le cas étudié ?
3	Un humain a-t-il validé chaque risque avant le rendu ?
4	Avez-vous comparé le résultat des agents à votre propre analyse ?
5	Avez-vous testé ce qui se passe si un document contient une consigne piégée ?
6	Aucune donnée réelle et sensible n'a-t-elle été envoyée à un service d'IA externe ?
7	Les outils d'IA utilisés sont-ils cités dans le dossier ?

Glossaire du projet

Terme	En une phrase
Analyse de risques	Identifier, évaluer et traiter ce qui peut nuire à un système
Registre des risques	Tableau qui liste chaque risque, son niveau et son traitement
DFD	Schéma des flux de données d'un système
STRIDE	Grille de six types de menaces (usurpation, falsification, répudiation, divulgation, déni de service, élévation)
Agent IA	Programme qui utilise un LLM et des outils pour atteindre un objectif
Orchestrateur	Agent qui coordonne les autres agents
Injection de prompt	Texte piégé qui détourne les consignes d'une IA
Humain dans la boucle	Validation humaine obligatoire des résultats importants

POUR ALLER PLUS LOIN

Ressources utiles

Thème	Référence
Gestion des risques	ISO/IEC 27005 ; ANSSI, méthode EBIOS Risk Manager
Modélisation des menaces	A. Shostack, Threat Modeling (2014) ; STRIDE ; LINDDUN (KU Leuven) ; MITRE ATT&CK
Vulnérabilités	NIST NVD (base CVE et notes CVSS) ; FIRST, CVSS v4.0
Sécurité de l'IA	OWASP Top 10 for LLM Applications (2025) ; MITRE ATLAS ; ANSSI, recommandations de sécurité pour un système d'IA générative (2024)
Cadre réglementaire	Règlement européen sur l'IA (AI Act) ; RGPD